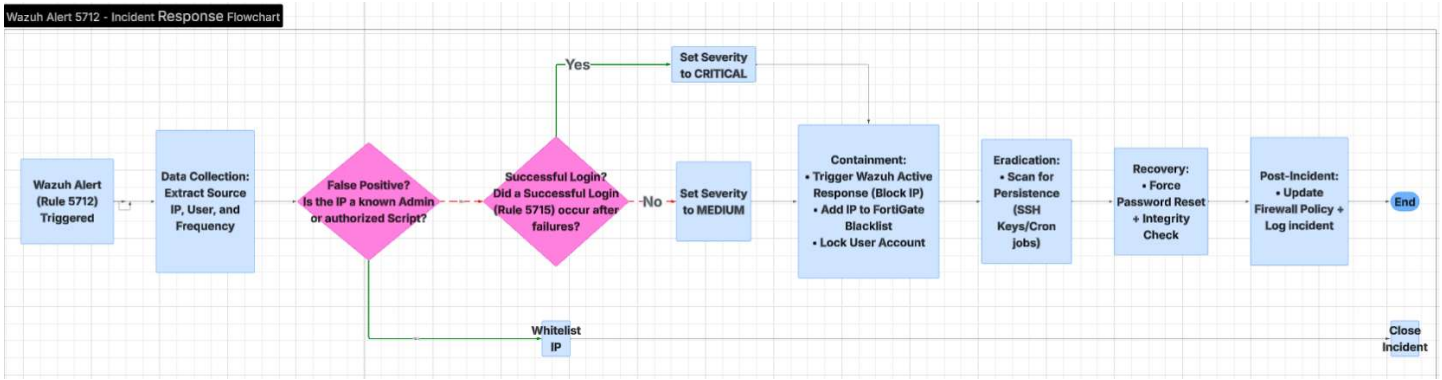
Playbook 1: SSH Brute Force Attack

Description: Repeated automated attempts to gain access to Linux systems via SSH.



Step 1 – Detection

- SIEM Alert: Wazuh Rule ID 5712 (SSHD authentication failed).
- Telemetry Source: /var/log/auth.log.
- Data to Record: Source IP, Target User(s), Frequency of attempts.

Step 2 – Investigation (False Positive Check)

- Check: Is the source IP an internal management station or a known SysAdmin?
- Check: Is there a scheduled automation task with expired credentials?
- Action: If the activity is localized and authorized, whitelist the IP and close the alert.

Step 3 – Classification

- Medium: If all attempts failed.
- High/Critical: If a "Successful Login" (Rule 5715) follows a string of failures.

Step 4 – Containment

- Manual: Execute iptables -A INPUT -s [Source_IP] -j DROP on the target host.
- Automated: Trigger Wazuh Active Response to null-route the IP for 24 hours.
- Account: If a specific user is targeted, lock the account: passwd -l [username].
- Firewall: Block the source IP at the FortiGate firewall for additional perimeter containment.

Step 5 – Eradication

- Remove any malicious SSH keys from ~/.ssh/authorized_keys.
- Scan for unauthorized persistence (Check /etc/cron.* and /etc/systemd/system/).
- Force a password reset for any targeted accounts.

Step 6 – Recovery

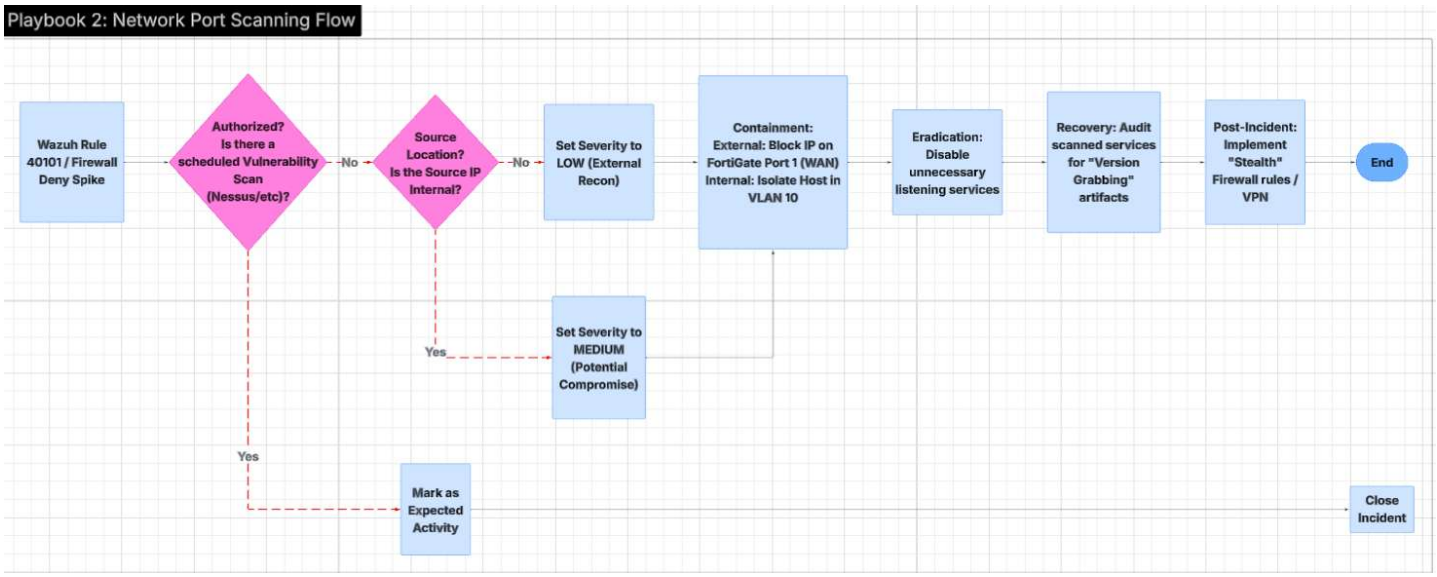
- Integrity Check: Compare system binaries (ls, ps, netstat) against known good hashes.
- Monitoring: Enable "Debug" level logging for SSH temporarily to monitor return attempts.

Step 7 – Post-Incident

- Document the Source IP in the "Known Bad" blocklist.
- Update firewall rules to restrict SSH (Port 22) to specific VPN ranges only.

Playbook 2: Network Port Scanning

Description: Reconnaissance activity identifying open ports and services.



Step 1 – Detection

• SIEM Alert: Wazuh Rule 40101 or Firewall "Deny" spikes.

• Data to Record: Source IP, range of ports scanned (Sequential vs. Random).

Step 2 – Investigation (False Positive Check)

• Check: Is a vulnerability scan (Nessus/OpenVAS) scheduled for today?

• Check: Is this a network monitoring tool (Nagios/Zabbix) checking service health?

• Action: If identified as an authorized scan, mark as "Expected Activity."

Step 3 – Classification

• Low: External scan blocked by firewall.

• Medium: Internal scan originating from a compromised workstation.

Step 4 – Containment

• Block the Source IP at the perimeter firewall (FortiGate).

• If internal, isolate the host from the VLAN to prevent lateral movement.

Step 5 – Eradication

• Identify and disable unnecessary listening services found during the scan.

• Update "Stealth" settings on firewalls to drop packets rather than reject them (hiding the host).

Step 6 – Recovery

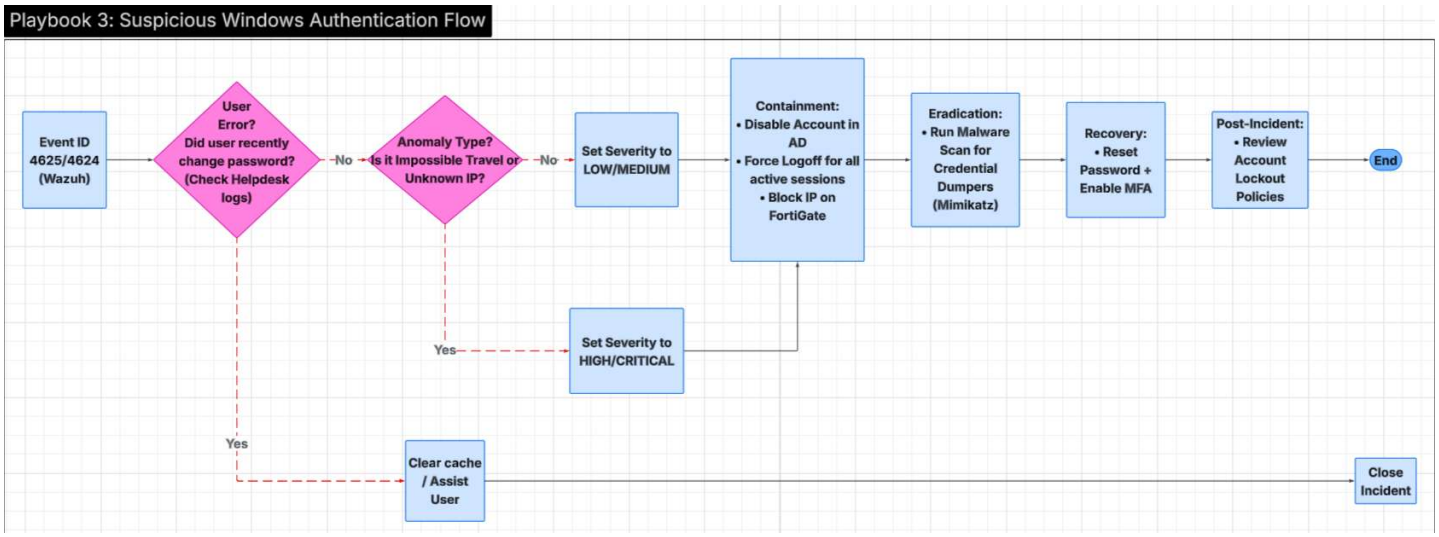
• Audit the services that were scanned to ensure no "Version Grabbing" led to further exploits.

Step 7 – Post-Incident

• Evaluate if "Port Knocking" or a Client-to-Site VPN should be implemented to hide services from the public internet.

Playbook 3: Suspicious Windows Authentication

Description: Abnormal login patterns or credential stuffing on Windows endpoints.



Step 1 – Detection

- SIEM Alert: Event ID 4625 (Logon Failure) or 4624 (Successful Logon).
- Data to Record: Workstation Name, Target Account, Logon Type.

Step 2 – Investigation (False Positive Check)

- Check: Did the user recently change their password? (Cached credentials often cause lockouts).
- Check: Is the "Source Workstation" the user's actual assigned hardware?
- Verify: Contact the user to confirm if they are currently attempting to log in.

Step 3 – Classification

- Low: Multiple failures followed by a success from a known user IP.
- High: Success from unknown IP or "Impossible Travel".

Step 4 – Containment

- Disable the account in Active Directory: Disable-ADAccount -Identity [Username]
- Terminate all active sessions: Invoke-Command -ComputerName [Host] ScriptBlock{logoff}.
- Firewall: Block any malicious external IPs at the FortiGate perimeter if detected.

Step 5 – Eradication

- Clear cached credentials on the compromised machine.
- Scan for "Mimikatz" or other credential-dumping tools using the SIEM/EDR.

Step 6 – Recovery

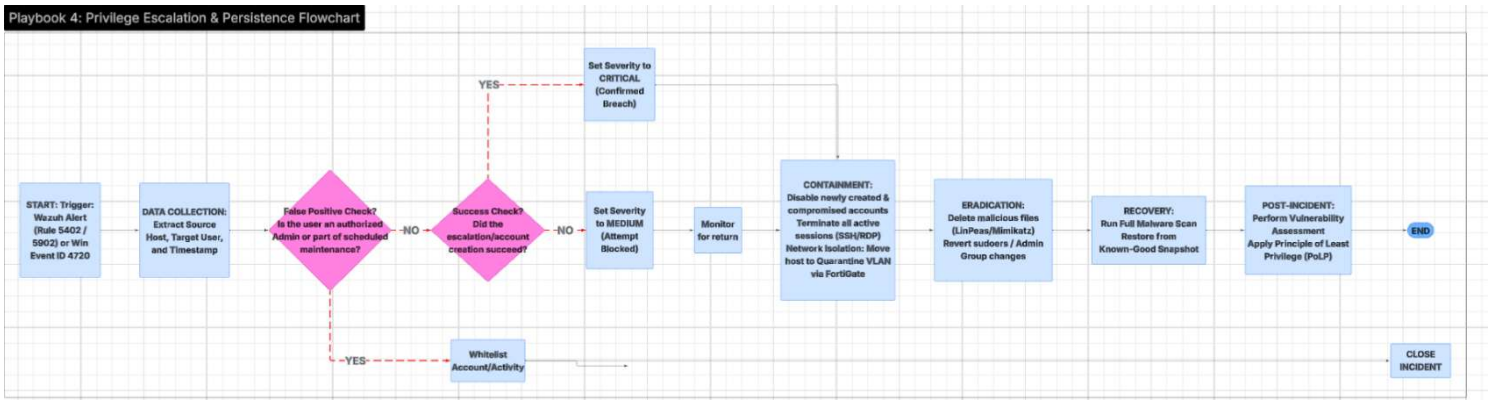
- Reset the user's password and revoke all Refresh Tokens (O365/Azure).
- Enable Multi-Factor Authentication (MFA) if not already active.

Step 7 – Post-Incident

- Review Windows Security Policy; implement "Account Lockout Thresholds" (e.g., lock after 5 failed attempts).

Playbook 4: Privilege Escalation & Persistence

Description: Detecting unauthorized attempts to gain administrative rights or create backdoors (New Accounts).



Step 1 – Detection

- SIEM Alerts: Wazuh Rule 5402 (Successful sudo usage).
    - Wazuh Rule 5902 (New user account added).
    - Windows Event ID 4720 (A user account was created).
- Telemetry Source: /var/log/auth.log (Linux) or Security Event Logs (Windows).

Step 2 – Investigation

- Check: Is the user authorized to perform administrative tasks (Is it the SysAdmin)?
- Check: Is the new account following the organization's naming convention?
- Verify: Cross-check with Change Management logs for any scheduled system.

Step 3 – Classification

- Critical: If an unknown user gains root/admin access or creates a new administrator account.

Step 4 – Containment

- Account: Immediately disable the newly created account and the account used for escalation.
- Session: Terminate all active SSH/RDP sessions for the compromised host.
- Network: Isolate the host from the network via FortiGate to prevent lateral movement.

Step 5 – Eradication

- Remove the unauthorized account and delete any malicious files used for the exploit (e.g., LinPeas, Mimikatz).
- Revert changes to the sudoers file or Windows Admin Groups.

Step 6 – Recovery

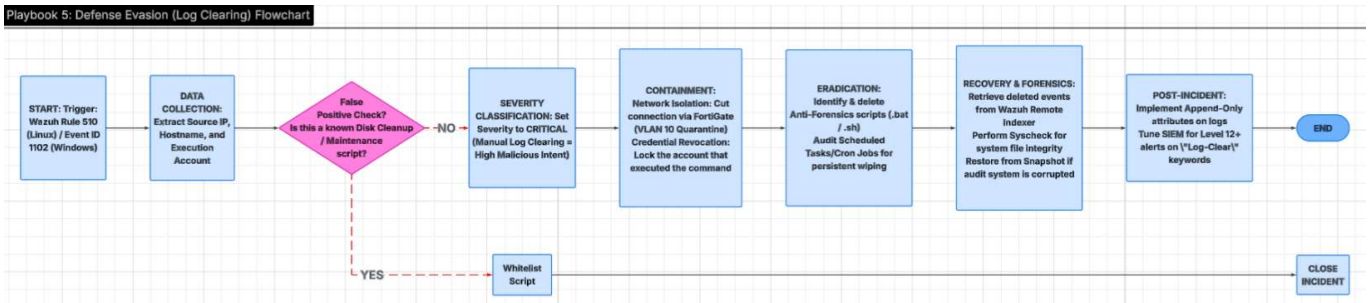
- Perform a full malware scan on the host.
- Restore the host from a Known-Good Snapshot to ensure no backdoors remain.

Step 7 – Post-Incident

- Conduct a vulnerability assessment to find how the escalation was possible.
- Implement the "Principle of Least Privilege" (PoLP).

Playbook 5: Defense Evasion (Log Clearing)

Description: Detecting attempts to delete evidence of the attack.



Step 1 – Detection

- SIEM Alerts: Wazuh Rule 510 (Log file deleted).
  Windows Event ID 1102 (The audit log was cleared).

Step 2 – Investigation

- Verify: Was this a script for disk space maintenance?
- Identify: Which account executed the clear command?

Step 3 – Classification

- Critical: Manual log clearing is almost always a sign of a malicious actor hiding their tracks.

Step 4 – Containment & Eradication

- Immediate isolation of the host from the VLAN 10 network.
- Revoke all credentials for the account that cleared the logs.

Step 5 – Eradication

- **Identify Compromised Accounts:** Determine which credentials were used to execute the clearing command and rotate them immediately.
- **Malware/Script Removal:** Scan for any "Anti-Forensics" scripts or batch files that are designed to wipe logs periodically.
- **Persistence Check:** Verify if the attacker created a "Scheduled Task" or "Cron Job" to clear logs to maintain stealth.

Step 6 – Recovery

- **Log Restoration (Remote):** Use the Wazuh Manager/Indexer to retrieve the events that were deleted from the local endpoint (since logs were forwarded in real-time).
- **System Audit:** Run a full system integrity check (syscheck) to ensure no system files were modified under the cover of the deleted logs.
- **Snapshot Reversion:** If the damage to the audit system is extensive, restore the machine from the Known-Good Snapshot.

Step 7 – Post-Incident

- **Hardening:** Implement "Write-Only" permissions or "Append-Only" attributes on critical log files where possible.
- **Alert Tuning:** Create a specific high-priority alert (Level 12+) for any command that includes keywords like wevtutil cl, rm -rf /var/log, or Clear-EventLog.